

What is LossLogic & Why Are We Building It?

A straightforward, no-nonsense explanation of our project, how the math works, and how to pitch it to judges.

1. The Real Problem in Plain English

Today, almost every company manages cybersecurity risks using colored charts: "This server is Red (High Risk), that server is Yellow (Medium Risk)."

The big problem is: **finance teams and CEOs don't care about colors. They care about money.**

If a cybersecurity team goes to the Chief Financial Officer (CFO) and says, "Our payment server is in the Red zone, please give us budget," the CFO immediately asks:

- "How much money could an attack on that server actually cost the company?"
- "If I give you a \$30,000 budget, which exact tools should we buy to save the most money?"

Security teams usually have no good answer because traditional "High/Medium/Low" ratings are just personal opinions.

The Old Way: Colored 5x5 Matrices

Companies multiply arbitrary numbers like *Likelihood (4) × Impact (5) = Score 20*.

This makes no mathematical sense. A score of 20 isn't twice as bad as 10. Everyone marks their server as "Critical" just to get budget, leaving leaders with no clue what to fix first.

The LossLogic Way: Real Dollar Math

LossLogic calculates risk in **real money (\$ / ₹)** using actuarial probability.

We tell leadership: "Your baseline expected loss is \$78,400 per year. With your \$25,000 budget, our optimizer picks 4 exact controls that reduce that loss down to \$24,800."

2. Indian Regulatory Pressure (RBI & SEBI)

This isn't just a theoretical problem. Financial regulators in India now require companies to quantify their cyber risk:

- **Reserve Bank of India (RBI):** Mandates banks to maintain board-level supervision over cyber loss exposure and conduct continuous stress-tests on payment networks.
- **SEBI (CSCRF Framework):** Requires stock exchanges and financial institutions to map system dependencies and demonstrate that cybersecurity spending is proportionate to financial risk.

Our One-Sentence Pitch for Judges:

"LossLogic replaces subjective red-amber-green risk heatmaps with actuarial financial math and an automated budget optimizer that picks the exact security tools giving the company the highest return on investment."

How The App Actually Works (The 3 Steps)

You don't need a PhD in math to explain this. Here is how our backend works step-by-step.

Step 1: The Connected Asset Map (Graph)

In a real company, computers are not islands. If an attacker hacks an employee laptop, they can steal login credentials, move to the Active Directory server, and then shut down the core banking database.

We model the organization's infrastructure as a **Directed Acyclic Graph (DAG)**. This allows us to calculate the **blast radius**: if one server gets compromised, which downstream services will fall with it?

Step 2: Monte Carlo Simulation (Open FAIR Standard)

Instead of guessing a single number, we use the industry-standard **Open FAIR model**. Our Python backend runs **10,000 what-if scenarios** for each threat:

- How many times per year will attackers attempt to break in? (Threat Event Frequency)
- What is the chance our current defenses block them? (Vulnerability / Resistance)
- If they break through, how much will we lose in downtime, customer compensation, and incident response? (Loss Magnitude)

From these 10,000 simulations, we get two essential numbers:

- **Expected Annual Loss (EAL)**: The average financial damage expected per year (e.g., \$78,400).
- **Value at Risk (VaR 95%)**: The worst-case loss in a bad year that happens 5% of the time (e.g., \$241,000).

Step 3: The Knapsack Optimizer (SciPy MILP)

Now comes the most valuable part of LossLogic: **spending the budget smartly**.

Suppose you have a budget of \$25,000. There are 8 different security controls you could buy (MFA, Backups, Firewalls, Endpoint Detection, etc.). Each control has a cost and a risk reduction score.

You cannot buy everything. How do you pick the best combination?

- **Why you can't just sort by ROI**: If you greedily buy the tool with the highest ROI first, you might run out of money and miss a pair of smaller tools that together would have saved more money. Also, some tools depend on others (e.g., you can't install Multi-Factor Authentication without an Identity server).
- **What we do instead**: We formulate this as a **0/1 Knapsack problem** and solve it using **SciPy's HiGHS Linear Programming Solver** in Python. In about 4 milliseconds, it mathematically proves the absolute best combination of tools for that exact budget.

The Data Reality: Why No CSV Upload?

Why we don't have a drag-and-drop file upload, and why our data is preset but 100% dynamic.

1. Why Isn't There a "Drag and Drop CSV" Button?

Teammates or judges might ask: "Can I upload my own company's CSV file to test this?"

Here is the honest, ground-reality answer:

- **In the enterprise world, CSV uploads are an anti-pattern:** Real corporate cybersecurity platforms (like CrowdStrike, Tenable, or ServiceNow) never ask a CISO to drag and drop a spreadsheet. Security spreadsheets become obsolete within 24 hours and are prone to human error. In production, enterprise risk platforms pull data automatically through **REST APIs and SIEM webhooks**.
- **We focused on building the mathematical engine:** During hackathon development, our time was spent perfecting the Monte Carlo simulations, the dependency graph, and the SciPy knapsack solver. Writing a generic CSV parser that handles broken formats and missing columns would have added zero real algorithmic value.

2. What is Preset vs. What is 100% Dynamic?

To showcase the platform cleanly, we initialized the app with a **realistic banking topology** (Core Banking Server, SWIFT Payment Gateway, Customer Database, Web Portal, and Active Directory).

It is crucial to understand that **the scenario is seeded, but the calculations are 100% live:**

Component	What is Seeded (Preset)	What is 100% Dynamic & Live
Company Servers	5 realistic banking assets & their relationships.	Cascading blast radius and failure propagation are computed dynamically through the graph.
Security Catalog	8 standard enterprise controls with estimated costs.	Prerequisite rules (e.g. MFA requiring IAM) and individual control effectiveness are evaluated on the fly.
Budget Optimization	Initial slider position (\$25,000).	Live SciPy solver execution: Moving the slider runs the linear program in ~4ms, producing real 0/1 purchase decisions.
Pareto Curve	Budget search range (\$0 to \$50k).	The curve line, knee-points, and Return on Security Investment (ROSI) are computed from real mathematical steps.

Key Point to Tell Judges:

"We seeded the app with a standard banking architecture so everyone can see the system working immediately. But nothing on screen is a hardcoded graphic or fake table — every time you move the slider, Python re-solves the mathematical optimization in real time."

Decision Support & How We Add Gemini AI

How our decision helper works today, and how Google Gemini 3.5 Flash Lite upgrades it.

1. How Decision Support Works Right Now

At the bottom right of our dashboard is the **Decision Support** panel. When you type or click a question like *"What is our highest risk today?"*, what actually happens?

- **Deterministic Rule Matching:** The backend checks your question using pattern rules and regular expressions.
- **Live Data Injection:** It looks up the live calculated results from the SciPy optimizer and Monte Carlo engine (such as which server has the highest loss and which control gives the best ROI).
- **Structured Summary:** It generates an executive explanation summarizing the numbers in clear English.

Why did we build it this way? Because in cybersecurity and finance, you cannot afford "AI hallucinations". Having deterministic rules guarantees that every number shown on screen is 100% mathematically grounded in our solver.

2. How We Can Upgrade It With Gemini 3.5 Flash Lite

We can easily upgrade this text box into a full conversational AI assistant using **Google Gemini 3.5 Flash Lite** (or Gemini 2.0 Flash) using **Function Calling (Tool Calling)**.

The Architecture: LLM as Orchestrator, Not Calculator

An LLM should **never** try to calculate risk numbers or solve knapsack math itself — it will hallucinate and guess random percentages. Instead, Gemini acts as the conversational interface that calls our Python functions:

1. **User asks a question:** *"What happens to our compliance if the Board cuts our budget by 30%?"*
2. **Gemini triggers a tool call:** Gemini recognizes it needs calculations, so it calls our backend function `run_optimizer(budget=17500)`.
3. **Our Python engine runs:** SciPy computes the exact optimal controls and compliance score for \$17,500.
4. **Gemini explains the answer:** Gemini takes the real numbers from our engine and explains them in a natural, executive memo.

Why Gemini 3.5 Flash Lite is Ideal for This

- **Ultra-Fast Latency:** Response times are under 250 milliseconds, making the UI feel instantaneous.
- **Extremely Low Cost:** It is lightweight and cheap to run, making it practical for continuous real-time queries.
- **Huge Context Window:** It can ingest entire regulatory PDF rulebooks (like the complete RBI or SEBI guidelines) and cite exact section numbers in its answers.

Judge Defense Cheat Sheet (Q&A)

Memorize these simple, direct answers for when judges grill our team during the presentation.

Q1 "Is your data hardcoded or fake?"

Our Answer: "The server names and default costs are seeded based on a standard commercial bank setup so you can see it working immediately. But the math is 100% real and dynamic. When you move the budget slider, our Python backend runs SciPy's HiGHS linear programming solver in real time (~4ms) to calculate the best controls and re-render the Pareto curve."

Q2 "Why did you use Open FAIR instead of just showing CVSS scores?"

Our Answer: "CVSS only measures technical severity in a vacuum. A critical CVSS 9.8 vulnerability on an isolated test server causes \$0 in business damage. But a medium CVSS 6.0 bug on our SWIFT payment server could cost millions. Open FAIR translates vulnerabilities into dollars of expected loss, which is the only language CFOs and Boards understand."

Q3 "Why does the graph stay flat after \$38,900? Is that a bug?"

Our Answer: "No, that is an intentional feature called budget saturation! In our catalog, buying every single available security control costs \$38,900. If you increase the budget to \$50,000, 100% of controls are already funded. Giving us more money cannot reduce risk further. The dashboard flags the extra \$11,100 as surplus so management doesn't waste capital."

Q4 "Where is the AI in your project?"

Our Answer: "We use Operations Research and Decision Intelligence — which is the mathematical optimization branch of AI used in hedge funds and aerospace. For conversational AI, our decision support is built to plug directly into Google Gemini 3.5 Flash Lite using tool calling, so management can ask questions in plain English without the risk of AI hallucinating fake numbers."

Q5 "How does this help with Indian banking regulations (RBI / SEBI)?"

Our Answer: "Both RBI and SEBI require boards to conduct quantifiable risk assessments and prove that security spending is proportionate to risk. LossLogic automatically maps each funded control to specific RBI and SEBI clauses, giving the bank an instant audit trail."

How to Demo the Dashboard in 60 Seconds

Follow this step-by-step walkthrough when presenting the live app to judges.



Figure 1: LossLogic Dark Theme Dashboard (Apple Liquid Glass design system with anchored Pareto curve).

The 60-Second Demo Script for Teammates:

1. **Show the Top KPI Cards (10s):** "Notice our baseline expected loss is \$78,400 per year. That's the financial risk the bank faces today without proper controls."
2. **Move the Budget Slider (15s):** "Watch what happens when I drag the budget slider from \$10k to \$25k. Notice how the numbers and selected controls change instantly. That is SciPy's linear programming solver running live in Python, picking the exact tools that maximize risk reduction."
3. **Point to the Pareto Curve (15s):** "This curve shows the investment sweet spot. Each milestone represents an optimal package of tools. Notice the white dot is anchored right on the curve line — that's our current budget selection."
4. **Explain the Asset Graph (10s):** "Here in the middle is our server network. If Active Directory gets compromised, the danger spreads to the Core Banking database. Our model calculates this cascading blast radius."
5. **Wrap up with Decision Support (10s):** "Finally, non-technical executives can look at Decision Support to get a plain English summary of what to do, with zero guesswork."

Final Reminder for the Team:

Be confident, speak in plain English, and emphasize that **we translate technical cyber risk into real financial numbers and optimal budget decisions.**